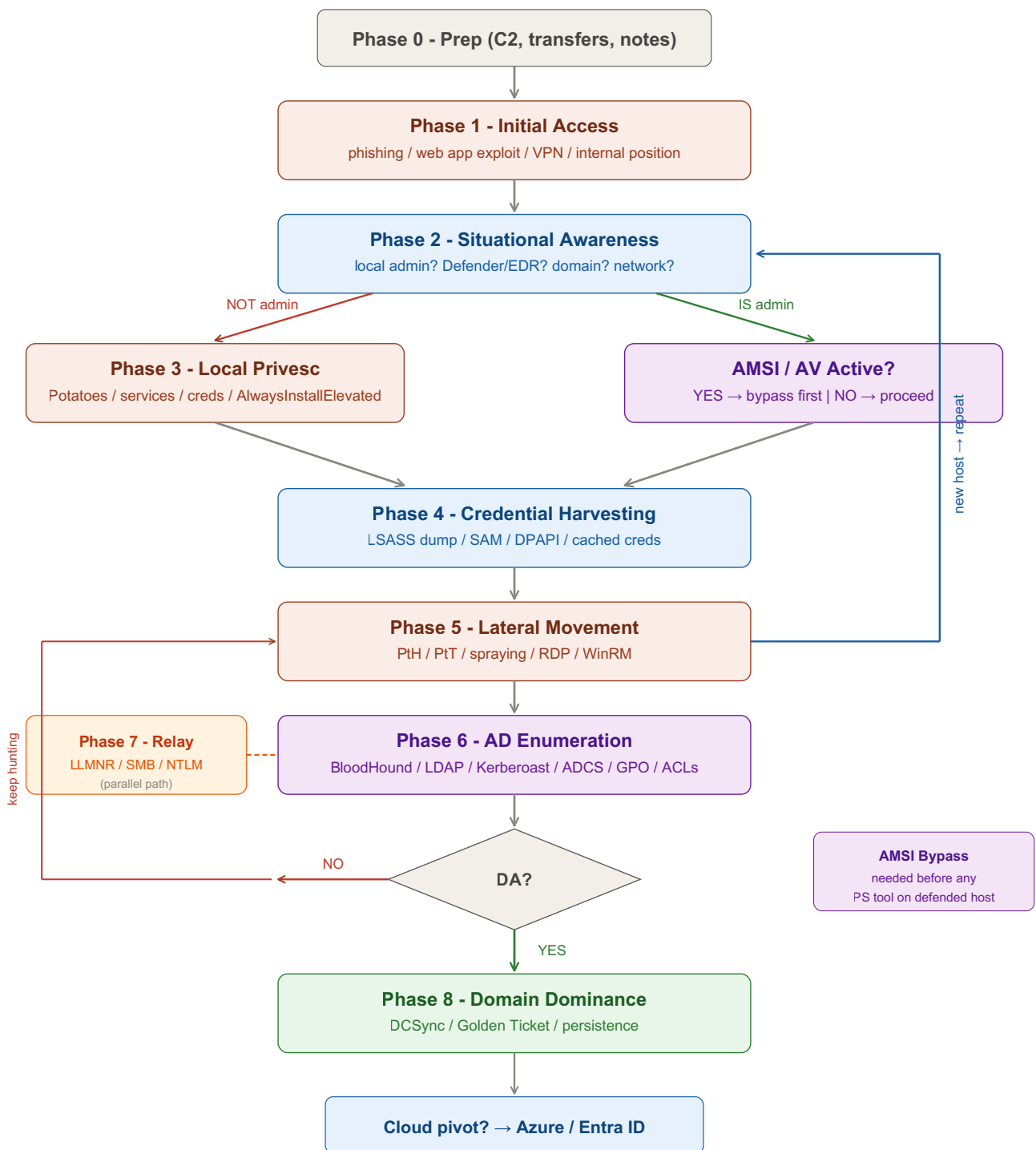


Windows AD Attack Chain

A high-level roadmap for attacking an Active Directory environment. This maps the flow from initial foothold to domain dominance and tells you what to do next based on what you have. For commands, see the dedicated cheatsheets.



the chain is a loop: land → enum → dump → move → repeat until DA → dominate

Phase 0 - Prep

Before touching the target environment, have your infrastructure ready.

Checklist:

- C2 framework deployed and listeners running (Sliver, Cobalt Strike)
- File-transfer methods tested (HTTP, SMB, certutil, PowerShell)
- Note-taking started — log every credential, hostname, IP, and path as you go

Phase 1 - Initial Access

Get your first foothold into the environment.

Already on the internal network (internal pentest)?

YES → skip to Phase 2, you ARE the foothold

NO → pick an entry method:

- Phishing / AitM — steal creds or get a callback
- Web application exploit — RCE, upload, SSRF to internal
- VPN / exposed service — exploit and get a shell

Once you have a shell or agent callback → Phase 2.

Phase 2 - Situational Awareness

Run this on every new host you land on. Understand where you are before doing anything loud.

Q1: Am I local admin?

YES (SeDebugPrivilege, Administrators group) → skip to Phase 4 (dump creds)

NO → Phase 3 (local privesc)

Q2: Is Defender / EDR running?

YES (MsMpEng.exe, Sysmon, CrowdStrike, Carbon Black) → bypass AMSI before any PS tooling

NO → proceed freely

Q3: Can I reach the DC and other subnets?

YES → continue

NO → set up a pivot / tunnel

```
whoami /priv
whoami /groups
tasklist
systeminfo
nltest /dsgetdc:
ipconfig /all
arp -a
netstat -ano
```

Phase 3 - Local Privilege Escalation

Only needed if Phase 2 showed you are NOT local admin. Try in this order:

SelmpersonatePrivilege? → **Potato attacks (GodPotato, PrintSpoofer)**
Weak service permissions / unquoted paths? → **service-based privesc**
Stored credentials? (cmdkey /list) → **runas /savecred**
AlwaysInstallElevated? → **MSI privesc**
Nothing local? → **try lateral movement (Phase 5) to a host where you ARE admin**

Phase 4 - Credential Harvesting

You have local admin. Dump everything you can from this host.

Is Defender / AMSI active?
YES → bypass AMSI first, then proceed
NO → proceed directly

Targets to dump:

- **LSASS memory** — `nxc -M lsassy` (in-memory, stealthiest) • `nxc -M nanodump` (syscalls, AV evasion)
- **SAM + LSA in one shot** — `nxc --sam --lsa` • `secretsdump.py`
- **LaZagne.exe all** — browsers, wifi, vault, DPAPI, everything on the box
- **Autologon / deployment leftovers** — registry Winlogon DefaultPassword • `unattend.xml` / `sysprep.xml`
- **Credential Manager / DPAPI** — browser creds, vaults, Wi-Fi keys
- **Cached domain creds (DCC2)** — crackable offline with hashcat/john

What did you get? NTLM hash → PtH | Kerberos TGT → PtT | Cleartext → direct auth/spraying | Nothing → Phase 4b (cred hunting)

Phase 4b - Credential Hunting (no admin needed)

Before going to full AD enum, check these easy wins — they don't need local admin and are often overlooked.

Passwords in user descriptions? → **`nxc ldap -M get-desc-users`**
GPP passwords (old Group Policy Preferences)? → **`nxc smb -M gpp_password`**
LAPS passwords readable? → **`nxc ldap --laps`**
gMSA passwords readable? → **`nxc ldap --gmsa` • `gMSADumper.py`**
Creds in shares (scripts, configs, KeePass)? → **`nxc --spider-shares` • `Snaffler.exe`**

Got something? → Phase 5 (lateral movement)
Still nothing? → Phase 6 (AD enum for escalation paths)

Phase 5 - Lateral Movement

Use captured credentials to move to other hosts. Pick based on what you hold:

NTLM hash? → **pass-the-hash (nxc, wmiexec, psexec)**
Kerberos ticket? → **pass-the-ticket, overpass-the-hash**
Cleartext password? → **nxc smb/winrm/rdp, password spraying**

Target selection — where to move next:

- Hosts where your creds have local admin
- High-value targets: DC, file servers, SCCM, ADCS, DB servers
- Hosts with logged-in privileged users (BloodHound sessions)
- Different subnet? → set up a pivot first

Every new host → go back to Phase 2. This is the loop: land → enum → dump → move → repeat.

Phase 6 - AD Enumeration & Escalation Paths

Map the domain and find privilege escalation paths. AMSI bypass needed for SharpHound/PowerView on defended hosts.

Kerberoastable SPN on a privileged account? → **Kerberoast it**
AS-REP Roastable account (no preauth)? → **AS-REP Roast**
ADCS misconfigured template (ESC1–ESC8)? → **abuse the template**
Delegation abuse (unconstrained/constrained/RBCD)? → **abuse delegation**
Writable GPO linked to high-priv OU? → **GPO abuse**
Can write msDS-KeyCredentialLink? → **shadow credentials**
SCCM/MECM misconfig? → **NAA creds, PXE abuse**
ACL abuse paths? → **GenericAll, WriteDACL, ForceChangePassword**
Nothing yet? → **password spray / relay attacks (Phase 7) / hunt creds in shares**

Phase 7 - Relay & Coercion Attacks

These don't require domain creds — just network position. Run in parallel with other phases.

SMB signing disabled? → **LLMNR/NBT-NS poisoning + SMB relay**
Can coerce auth from DC / high-value server? → **PetitPotam, PrinterBug, DFSCoerce**
ADCS web enrollment exposed? → **coerce + relay to ADCS (ESC8)**
IPv6 unclaimed? → **mitm6 + LDAP relay**

Phase 8 - Domain Dominance

You have DA or equivalent. Secure full domain control.

- **DCSync** — dump every hash in the domain (secretsdump.py with DA creds)
- **Golden Ticket** — forge TGTs with krbtgt hash, survives password resets
- **Silver Ticket** — forge TGS for specific services, stealthier
- **Persistence** — scheduled tasks, registry, DLL hijack, etc.
- **Forest trusts?** — SID History, cross-forest Kerberoast, trust keys
- **Cloud connected?** — pivot to Azure / Entra ID

When to Bypass AMSI — Quick Reference

NEED bypass (Defender is on + running these on target):

- Mimikatz / Invoke-Mimikatz
- Rubeus
- PowerView / SharpView
- SharpHound (PowerShell collector)
- Any offensive PS script

DON'T need bypass:

- Python tools from attack box (impacket, nxc)
- C# via execute-assembly in C2
- LOLBins (certutil, rundll32)
- Anything running from your Linux box

Key idea: AD pentesting is a loop — land on a host, enumerate, dump credentials, move laterally, repeat. Check for AMSI/Defender before running any PowerShell tooling on target. Use BloodHound to find the shortest path to Domain Admin. Once there, DCSync + Golden Ticket = game over.